1 Comparing Data Laws From 3 Separate Jurisdictions: Local Washington State, Federal U.S, and the European Union

Alvin, AT, Ton

Author, Western Washington University, Bellingham, WA, U.S.A, tonk4@wwu.edu

ABSTRACT

This paper examines three separate data law-related topics; health data privacy, data breach notifications, and biometric data handling and further compare how these laws are implemented at the local level (Washington State), the U.S Federal level, and how also how the laws are implemented in the European Union. At each geographical level, a discussion of the law's scope will be mentioned, along with factors that go over why the laws are implemented in the way that they have through contextual influences like the intent, cultural differences, differing legal landscapes, and overall experience. The different rationale and scale of the laws in turn also determines how IT and Cybersecurity will be affected, so a discussion of how these laws affect the implementation of cybersecurity within the respective jurisdiction will be had as well. The analyses of the three data law topics seek to illustrate how geography can vastly affect how data is regulated.

CCS CONCEPTS

• Health Data Laws • Data Breach Notification Laws • Biometric Data Laws

KEYWORDS

Special Category, MHMDA, RCW, GDPR, FTC, DHS.

2 INTRODUCTION

Technology has been continually innovating at a rapid pace within the past few decades, and common concern and contention comes from consumers using products created by corporations and how consumer data is being handled and processed. As data breaches appear to have become more prevalent in the past few years, there have been more vocal concerns about how user data and privacy is handled by companies, how user data is being misused, and an overall push for more lawmakers to develop and enforce regulations with security practices that protect user privacy [1]. This paper seeks to explore the laws that're put in place regarding data and management to first answer and see any laws that are in place to tackle certain topics, but then also to see how the laws are being implemented.

It was discovered that there are similar laws tackling the same issue in different ways depending on the jurisdiction and scale, and the geographical location itself and contains different cultures and approaches to data handling, which in turn affects how the laws are implemented in the respective jurisdiction. This paper focuses on three separate topics; health data privacy laws, data breach notification laws, and biometric data protection laws and comparing how the implementation of these topics overlaps and differ at a local level (Washington State), at the United States federal system level, and then at the European Union. Comparing the different jurisdictions reveals how different regions approach data laws; with Washington State emerging to implement a consumer privacy model, the United States with the segmenting of laws by sector approach, and the European Union's broad fundamental human rights-based approach on privacy and data protection through the GDPR [1, 2, 3]. This paper will compare the three topics at three different geographical levels and then continue to go understanding the differences through contents of the laws, the effective scope, intent, historical experience, cultural values, and any differences in the legal landscape.

By going through these regulatory differences, the paper highlights how different jurisdictions affect how policies are made and in turn determines how cybersecurity is implemented within the companies and entities that're responsible for complying with the laws.

3 HEALTH DATA DEFINITION AND PURPOSE

The following section discusses laws related to health data privacy. Each jurisdiction defines health data privacy differently. The following sections cover how the different topics define health data and explore aspects for why the laws are implemented differently.

Washington State defines health data within MHMDA (My Health My Data Act) as any form of data (used in clinics or not) that is identifiable or can be used to infer the individual's physical/mental health [4]. MHMDA is outlined as a section within RCW (Revised Code of Washington) itself, where RCW is a "compilation of all permanent laws enforced within the state of Washington" [4]. Washington State MHMDA is the broadest definition of health-related data of the three jurisdictions mentioned, and any entity that handles consumer health data must comply under this definition outlined in RCW 19.373 [5].

MHMDA was passed in April 2023 and was designed to take the definition of health data outlined by HIPAA and expand the scope to cover software and applications who handle health data but aren't required to be compliant under HIPAA [4]. Aspects of health data that MHMDA gathers that HIPAA doesn't include any health apps like wellness apps, fitness apps, nutrition apps, which all gather individual health-related data but isn't covered by HIPAA [6].

At the United States Federal Level, HIPAA (Health Insurance Portability and Accountability Act) defines health data as PHI (Personal Health Information), which is any health information that is used to identify an individual, and exists to create, receive, maintain, or received by a covered entity or business associates tied to the covered entity [7.] A covered entity is defined by any organization or individual like healthcare providers and facilities who must comply with HIPAA regulations [7]. Medical histories, prescriptions and diagnosis result all fall under PHI, but other health-adjacent data through apps like fitness trackers, menstrual apps, and wellness apps are not processed by covered entities, so these companies don't need to comply under HIPAA [8].

HIPAA was passed in 1996 for the purpose of having a standard for electronic healthcare transactions and protecting medical records [7]. Due to the sectoral model that the U.S had at the time, HIPAA was never meant to be a centralized policy for data privacy but was rather designed to govern the healthcare sector and how covered identities and business associates handled health data [8].

The European Union under the GDPR (General Data Protection Regulation) is used to standardize how data privacy is handled across many countries belonging to the EU [9]. When specifically referring to health, the GDPR defines health data all forms of personal information that can be related to an individual's physical/mental health, any services used, and any information about the current health status of the individual [9]. Data concerning health is further defined as a special category, which highlights that health data requires more protection and security over general personal data [9]. The broadness of data concerning health is best described as somewhere between MHMDA and HIPAA, where medical information like records, treatments, history, and diagnoses falls under the definition, as well as other personal data like genetic data, biometrics, and any data collected by apps that reveal or can infer an individual's health [4, 5, 9].

The GDPR (General Data Protection Regulation) regarding health data is a centralized law as opposed to HIPAA which is sector specific and MHMDA which goes over aspects not covered by HIPAA [4, 5, 8 ,9]. The reason for the creation of the GDPR comes from how Europe treats individual privacy as a human right, which is reflected through the GDPR and how the laws give more control to citizens over personal data [10].

Going over the differences in how each jurisdiction defines health data helps gives context to how the laws are applied, who the laws apply to, and why the laws are defined in the way they have.

3.1 Comparing Health Data Laws (Local WA, U.S, EU)

The following section will cover and compare the equivalent laws in the different jurisdictions based on the contents of the laws.

Washington State's MHMDA contains information on how various types of data should be handled, but RCW 19.373 is the section that specifically covers health related data [4]. The mentioned requires that any entities conducting business in Washington State (regulated entities) that interact with health-related data have a personalized consumer

health data privacy policy, and must disclose what data is collected, used for what purposes, who the data is being shared with, and any and all rights that the consumer has when interacting with the data [4]. Furthermore, any regulated entities who want to sell any consumer data must disclose and obtain valid written authorization from the consumer, along with specifications of who the data is being sold to, the reason for selling, and giving consumers the right to withdraw from the selling of the data [6]. Any regulated entity who wants to process more information than initially stated or wants to update policies must first disclose and obtain consent from the consumer before any changes are made [4]. On the side of the consumer then, the mentioned requirements are essentially rights given to the consumer [4]. Consumers have the right to know what is happening to their data, all the parties the entity is sharing the data with, how to contact the parties, and the right to access, delete, and withdraw from involved systems upon request [4]. The broad definition of health data is also applied in a broad way when it comes to disclosure, transparency, and overall consumer rights when it comes to health data [6].

When it comes to the United States and HIPAA policies talks about what types of health data is safeguarded and the process of how to secure the data [7]. The law limits the use and disclosure of PHI by only allowing covered entities and business associates to use patient health data for the purposes of healthcare, healthcare related payments, and information for operations, while uses for other reasons usually require individual authorization [8]. These policies are only required by entities who're defined as covered entities and business associates of covered entities, so the scope of HIPAA is less compared to MHMDA [4, 8].

The European Union and the GDPR cover health related data under Article 9 [9]. Health data is described as a special category, making processing health data prohibited except when given explicit consent, for medical care purposes, or for disclosure of public interest [9]. Furthermore, data belonging in the special category calls for tighter security and often requires regular DPIA (Data Protection Impact Assessments) conductions to weigh the impact and value of health data stored within a database [9]. The GDPR gives EU citizens the right to access, rectify, erase, and restrict the usage of data [9]. Furthermore, the GDPR applies to any data that is gathered from EU citizens even if the data isn't stored in a country residing in the EU [10].

The main differences seen between MHMDA, HIPAA, and GDPR is that MHMDA and GDPR have broad definitions of health data and gives general rights to consumers to handle their personal data [5, 8, 9]. The main difference between the two is that GDPR is more defined [9]. HIPAA differs from the other 2 laws because the scope is specifically related to entities like healthcare facilities and limits how the data is allowed to be used [4, 8, 9]. HIPAA does not cover other health-adjacent data collecting corporations in the same way that MHMDA and the GDPR does [4, 8, 9].

3.2 How Health Data Laws Impact Cybersecurity Practices

The following sections discuss how the contents of MHMDA, HIPAA, and GDPR article 9 affects how cybersecurity should be implemented within the respective jurisdictions.

Based on specified guidelines and the contents of the policies mentioned, MHMDA requires health data protection under RCW 19.373.050 to restrict data to only those who need access to the data (third parties, entities, employees) by having technical, administrative, and physical security practices to protect aspects of the CIA of consumer health data.

Consumers have the right to ask how data is processed and flows within a system, so there is a requirement to use various monitoring tools for databases, logging, and analytics to always be tracking how data is being moved within or between databases.

To complement the content of HIPAA regulations, the outlined requirements for cybersecurity practices mention that there should be implementations of access control, and audit logging for systems storing PHI data. There is a minimum necessary set of access practices required by HIPAA, along with consistent security risk analysis, and incident responses. All these practices are generally bare minimum practices and expectations for covered entities and business associates.

Compared to the other 2 laws, EU's culture of treating privacy as a human right is reflected through GDPR's recommended implementations of cybersecurity by pushing for infrastructure that promotes privacy by design. GDPR requires aspects like data minimization, which is the concept of only collecting enough data that is needed for the purpose that is needed. Data minimization works in conjunction with purpose limitation, which goes over how data should only be used for the purpose that was defined, and not for any other reason unless disclosed and asked for

permission. Consistent DPIAs are required to gauge the risk that health data has at any given time. Furthermore, strong logging is required, with breach handling, and vendor oversight for any processes involving health data.
Overall, the recommended controls coincide with the scope of the laws, and based on the specificity, the amount of cybersecurity controls differ. For MHMDA, there are more controls that contribute to transparency between companies and consumers, while HIPAA focuses on controls to make sure PHI is secure, and GDPR takes a combination of both U.S laws with more specificity due to the EU cultural view of privacy being a right.

4 DATA BREACH NOTIFCATION DEFINITION AND PURPOSE

Overall, the definition of a data breach between the three jurisdictions has more overlap than the definitions of the previous section but still have a few key differences in scope.

For data breach notification laws for Washington state, RCW is once again applicable, and contains a section used to define data breaches within RCW 19.255 as an authorized collection of data that comprises any aspect of the confidentiality, integrity, or the security of information kept by the business or individual [11]. This is a standard definition of what a data breach is, but the scope differs by only applying to personal information of Washington state residents like medical information, biometrics, passwords, or even a partial name of an individual [12].

Due to the United States working with a sectoral model, there are different data breach notification laws that only apply to the sector it belongs to [2]. For the example that is used for this topic, HIPAA references HITECH and the HHS (Department of Health and Human Services) when it comes to the data breach notification laws [13]. The definition of a data breach according to HHS is an "unauthorized use or disclosure of data that compromises either the security or privacy of PHI" [13]. The nature of this data breach notification law applies to the disclosure of breaches specifically for covered entities or business associates [13]. Any information that is not handled by the entities mentioned is not considered PHI and would not be considered a breach that concerns HIPAA and the healthcare sector [13].

In the EU, the GDPR article 34 defines a data breach in "security that leads to unlawful destruction, loss altering, access to, disclosure of, or transmitting of data in an unauthorized manner" [14]. Any personally identifiable data, whether considered special category or not, is part of the potential data that could be involved in a data breach [14]. Compared to the RCW sections relevant to data breach notifications, GDPR is broader due to the definition involving leaking of any personal data, not like just including highly confidential personal information like medical information and passwords [12, 14]. GDPR also goes deeper by mentioning accidental loss, deletion, or corruption, which is a definition beyond just unauthorized acquisition or disclosure [15].

4.1 Comparing Data Breach Notification Laws (Local WA, U.S, EU)

The data breach notification law for Washington State is outlined under RCW 192.255 and RCW 192.255.010, where any entities involved with a data breach must send notice to affected Washington State residents, and must report directly to the attorney general if there were more than 500+ residents who were impacted [11, 12, 16]. Furthermore, if it's seen that the attorney general requires to be notified, the company must include within the list and notify how many residents were affected, the list of company assets that were affected, a timeline of the exposure, the date of the breach itself, documentation for all steps that were taken, and a copy provided for the attorney general that contains what contents the company wants to communicate individuals who were affected [16]. The disclosure of a breach itself must be notified to the attorney general and affected residents in a reasonable timeframe, with a maximum length being 30 days after the discovery of the breach and would only be extended if the 30-day timeframe would impede an ongoing criminal investigation [16].
Again, for the United States, there are different data breach related laws separated by sector, and for this paper and section, HIPAA will be used as the focus for discussing the breach notification law and is by no means the only law that is used to govern disclosure at the federal level [13].
The current HIPAA law regarding data notification is enforced by the FTC (Federal Trade Commission), while also referencing the notification laws of HITECH section 13407 [13]. The law requires covered entities and business associates to notify three groups: those who have been affected, the secretary of the HHS (The U.S Department of Health and Human Services), and potentially interact with the media if the breach has affected more than 500 residents

within the affected jurisdiction [13]. However, if the breach was of PHI that was encrypted, then there can be a case made with the HHS, making disclosure to individuals unnecessary [13]. In general, the disclosure must include a document including the date of when the breach was discovered, a concise description of how the incident occurred, including any PHI potentially exposed [13]. Furthermore, the disclosure will include what steps should be taken for individuals to protect themselves, and the current steps the company is taking to alleviate the issue [13]. Self-protection recommendations could include requests for individuals to monitor credit reports, changing passwords, and watching suspicious activity, while the company will investigate and mitigate the breach, and any steps the company takes that're relevant to the situation [13]. The notification itself must occur within 60 days following the finding of the breach and any information written in the notification must be consistent among all individuals who were affected [13].

Most of the notification guidelines between Washington state and HIPAA are fundamentally the same, but there are slight differences based on the scope [11, 13]. For example, HIPAA requires the notification to occur within 60 days of the data of breach, while RCW requires 30 days [13, 16]. RCW requires any individual or group within Washington State to report to the attorney general if the breach affected more than 500 individuals, but HIPAA requires only covered entities and business associates to and reports to the HHS instead [13, 16].

Data Notification Laws for EU are outlined in GDPR article 33 and 34, where the former focuses on conditions to notify an authority, while the latter focuses on conditions to notify EU residents [14, 15]. In general, companies are required to store documentation of all data breaches within the company, whether the breaches meet the conditions to be notified or not. This includes, any facts found, the impact of the breach, and all remedial actions taken [14, 15]. At the bare minimum of a breach detection, the supervisory authority that overlooks breaches located at the home European country of the company needs to be notified within 72 hours of the discovery of the breach. However, if the breach results in a high risk of impact to any of the individual's rights, then those were affected must be notified as well, no matter how many individuals were affected [14]. The distinction of when to notify the former or both depends on the gauging of the risk being moderate or less versus high risk [15]. If the risk of breach by the company can be proven to the supervisory authority is moderate risk or less, then disclosure to individuals affected is not necessary [15]. For example, a breach of only encrypted data could be argued to be a moderate to low risk and could potentially be the difference between having to notify all individuals affected [15].

Between GDPR's data notification law and HIPAA and RCW, GDPR differs mostly from the detail that a notification occurs even when there was a breach of even 1 person affected [11, 13, 15]. There is no limit of 500 like the latter 2, and the time limit to disclose is a lot more frantic as well, being only 3 days to disclose the breach [15]. This distinction in time constraints in the GDPR law will affect how cybersecurity is impacted and prioritized within companies within Europe versus the United States.

4.2 How Data Breach Notification Laws Impact Cybersecurity Practices

The following section discusses how the contents of RCW, HIPAA/HITECH, and GDPR article 33 and 34 affects how cybersecurity is implemented within the respective jurisdictions of Washington State, Federal United States, and the European Union.

The main consistent cybersecurity procedures that's required for all three laws is having defined processes to best communicate with an authority and individuals affected [11, 13, 15]. Meeting the deadlines as fast as reasonably possible requires very specific detection tools and procedures put in place to ensure that the information gathered is streamlined [11, 13, 15]. Requirements consistent between all three of the laws include having monitoring and logging for all data that is interacted with, and data mapping to understand how and where data is accessed and moved within and between systems [11, 15]. Encrypting is ideal because in many cases it could remove the need to notify individuals affected [11, 15]. Although it isn't necessary for WA state under RCW to conduct risk assessments like it is for HIPAA and GDPR, risk assessments should be routinely conducted to understand how vulnerable consumer data is to prevent the likelihood of a breach [11, 13, 15].

Companies under HIPAA/HITECH are responsible for the cybersecurity infrastructure of business associates, because companies can be held liable for sharing PHI to recipients that aren't secure [13]. For that reason, business associate oversight is necessary for covered entities, and any business associates who are involved should also follow the same or similar standards to the covered entities [13].

Of the three laws mentioned, GDPR requires controllers to have all required results within a significantly shorter amount of time [14, 15]. The 72-hour time constraint means that companies within the EU cannot afford to not optimize for the best ways to gather all relevant information for a disclosure [14, 15]. Comprehensive accountability mechanisms are required, along with strict data minimization and streamlined DPIAs [15].

5 BIOMETRIC DATA DEFINITION AND PURPOSE

The definition of biometric data is any physical or behavioral trait(s) that're used to uniquely identify an individual person [17]. Biometric data isn't fundamentally defined differently between Washington state, federal U.S, and the European Union. The differences, however, are almost entirely on the scope of the usage of biometrics.

The scope of Washington State's RCW biometric data law applies to commercial entities and the policies around engaging in collecting biometric data [18]. The incorporation of a local biometric law in Washington was due to legislation anticipating the mis-use cases of biometrics, so a law was made to regulate biometrics before the use became widespread [18].

The U.S federal level's scope depends on two main factors, which is to enforce market fairness and national security for surveillance purposes [19, 20].

GDPR treats all forms of personal data as human rights, and much like data related to health, the GDPR treats biometrics as a special category, which means that the data must be treated with more security and care than general personal data [21].

5.1 Comparing Biometric Data Laws (Local WA, U.S, EU)

When it comes to biometric data laws, Washington State is mainly concerned with how commercial entities are allowed to collect data. Defined in RCW 19.375, and much RCW 19.373 for health data, commercial collection of biometrics is only allowed if companies give notice, obtain consent, provide a way to opt-out of the service, and a way to request for the data to be removed from the database upon request by individuals [4, 18]. Furthermore, businesses that collect biometric data cannot freely share, sell, or disclose the data unless the customer requests for a service that requires that data to be used, the data is needed for a financial transaction, is needed in court, or consent is given to a recipient not mentioned previously and the recipient can contractually promise confidentiality and cannot be recreated in any other database [18]. However, the only exception where a company does need to disclose the usage of biometrics is if the data is used only for the sole purpose of security [18].

When regarding the storage of biometrics in Washington, reasonable care needs to be taken to prevent unauthorized access, and the storage is only kept as long as is needed for the purpose that the biometrics is used for [18]. For example, storage of biometrics for legal reasons or fraud prevention could be kept longer, while the usage for one time identification needs to be removed immediately after being captured [18].

At the federal United States level, there is no direct biometric privacy law that applies to companies, but the FTC (Federal Trade Commission) article 5 can be applied to enforce biometric practices for the reason of unfair or deceptive practices [19]. For example, if a company is lying or deliberately has a lack of transparency about what data is being used, then the FTC can be involved in investigating a company for being unfair or deceptive [19]. However, outside of these reasons, the respective local laws carry most of the weight concerning biometrics [19].

In other cases, federal agencies like the DHS (Department of Homeland Security) are given high authority over how they collect and store biometrics [20]. The DHS can gather biometrics without consent and provide no rights for deleting data or opting out of the data being stored [20]. The data can be used and shared with other government agencies federally or internationally for the main purpose of identification and surveillance at border controls [20]. Non-citizens have no rights when it comes to interacting with personal records kept by the DHS, while citizens have limited rights to at least access personal records, correct inaccurate records, and have general protection against unwarranted disclosure of personal biometric data, and the ability to bring legal action for violations of these limited rights [20].

For the European union, biometric data is a special category under article 4 and 9, which means that the data is given extra protections and is explicitly prohibited to process unless a specific exception is given, much like health and genetic information [21, 22]. These exceptions could include explicit consent provided by the individual, employment

reasons, or substantial public interest [21]. Special category data is considered high-risk and requires strict security safeguards [21, 22].

The scope of all three of these laws are vastly different; with WA centered around preventing commercial biometrics usage abuse, the U.S preventing unfair competitive practices, and the GDPR preventing biometric misuse for all entities [18, 19, 20, 21].

5.2 How Biometric Data Laws Impact Cybersecurity Practices

Even though all the jurisdictions mentioned for RCW, FTC/DHS, and GDPR define the topic of biometric data similarly, the differences in the scope of use for biometrics and obligations differ, leading to different cybersecurity strategies.

GDPR and Washington's RCW 19.375 law for biometrics requires that systems have a built-in function for giving notice and taking consent from the users before gathering biometric information [18, 21]. When information is gathered, the use by the company is very limited, and should be tightly controlled [18, 21]. Access controls should be implemented granularly to ensure that data is accessed for approve purposes, and overall logging and monitoring is a must for every interaction with biometric data for the company to always know how the data flows to communicate with the individuals and authorities upon request [18, 21]. Companies should always know what data is being collected, used for what purpose, who the data is being shared with, and always cater to individuals who request to delete, withdraw, or access the data. This creates audit trails that can be used for situations of breaches but also consistent monitoring for tracking unusual activity [18, 21].

To meet the deadlines for GDPR (72 hours) and Washington State (30 days), documented incident response plans are required, with a clear workflow for decision making to determine breach severity. Having concrete processes and audit trail makes the gathering of information always readily available while also knowing what to do in the case of an incident [18, 21]. Training and handling data will help personnel know how to interact with sensitive data, while also being educated in incident responses to cover all bases.

All these cybersecurity controls are relevant and should be applicable to the systems and companies that the laws overlook [18, 21]. GDPR and Washington's RCW 19.375 are more aligned in the defined goals of the laws, but the main difference between the two is that GDPR is more granular and specific, and RCW 19.375 is more general and less focused [18, 21]. The recommended security controls that were commended are that each aspect for storing and handling biometric data will be stricter with the GDPR than with RCW 19.375 [18, 21].

As for the United States and the DHS/FTC, there is a lot of gaps in information for how the department handles biometric data [20]. A lot of the practices mentioned previously should be applicable to the DHS and other similar agencies, except they do not need audit trials or other practices for the purpose of communication and disclosure to the public [20]. In general, it is safe for those working at the DHS to incorporate best practices for internal risk frameworks like NIST and ISO 27001 for general data retention [20].

6 CONCLUSION

By comparing the differences between health data privacy laws, data breach notification laws, and biometric data laws across the three jurisdictions of Local Washington State, the U.S Federal system, and the European Union, it is seen that all three jurisdictions contain different scopes, and often times different definitions, which is fundamentally used to shape the differences in how the cybersecurity practices within each jurisdiction is conducted. For example, Washington's RCW MHMDA works with privacy regulations that fill gaps left out by the sectoral based model of HIPAA and the U.S, which created a different scope and focus that HIPAA never intended to cover in the first place [4, 7]. The EU's GDPR fundamentally stands out from the fragmented U.S laws and RCW laws from Washington State by treating security as a right, and the culture created on the top is reflected by imposing strict and unified laws in the mentioned topics of health, biometric data, and defined policies for how to notify those who were affected in case a data breach occurs [9, 14, 21].

The differences seen between the laws show how the intent and culture guide the laws that're created with each jurisdiction. EU prioritizes privacy as a human right and is then reflected through the creation of a centralized method of enforcement [9, 14, 21]. The U.S Federal system values a sector-specific regulation approach and is translated to regulations that're only relevant to the department that it is created for [7, 20]. Washington State is beginning to value

consumer protection and covering for differences and lack of regulations at the federal level, and so often Washington is an extension of what laws are already created from the federal level [4]. Understanding what laws are present at different jurisdictions provides understanding in how different regions value cybersecurity and comparing the differences in implementations reveals best practices that should be set for cybersecurity.

REFERENCES

[1] Pew Research Center. 2023. *How Americans View Data Privacy.* Retrieved November 20, 2025 from https://www.pewresearch.org/internet/2023/10/18/how-americans-view-data-privacy/
[2] USA.gov. n.d. *About the U.S. and its government.* Retrieved November 20, 2025 from https://www.usa.gov/about-the-us
[3] GDPR-Info. n.d. *General Data Protection Regulation (GDPR).* Retrieved November 20, 2025 from https://gdpr-info.eu
[4] Washington State Legislature. 2023. Chapter 19.373 RCW: Washington My Health My Data Act. Retrieved November 20, 2025 from https://app.leg.wa.gov/RCW/default.aspx?cite=19.373&full=true
[5] M. Hintze. 2025. The Washington My Health My Data Act: Not just Washington (or health). Retrieved November 20, 2025 from https://calawyers.org/privacy-law/the-washington-my-health-my-data-act-not-just-washington-or-health
[6] C. Bahr. 2025. Washington My Health My Data Act: A comprehensive guide. Retrieved November 20, 2025 from https://usercentrics.com/knowledge-hub/washington-my-health-my-data-act-guide
[7] U.S. Department of Health & Human Services. n.d. Laws & regulations – HIPAA security, privacy & enforcement. Retrieved November 20, 2025 from https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html
[8] U.S. Department of Health & Human Services. n.d. The HIPAA Privacy Rule – Privacy (for professionals). Retrieved November 20, 2025 from https://www.hhs.gov/hipaa/for-professionals/privacy/index.html
[9] GDPR-Info. n.d. Article 9 – Processing of special categories of personal data. Retrieved November 20, 2025 from https://gdpr-info.eu/art-9-gdpr
[10] GDPR.eu. n.d. What is GDPR? Retrieved November 20, 2025 from https://gdpr.eu/what-is-gdpr
[11] Washington State Legislature. n.d. Chapter 19.255 RCW: Personal information—Notice of security breaches. Retrieved November 20, 2025 from https://app.leg.wa.gov/rcw/default.aspx?cite=19.255&full=true
[12] Washington State Legislature. n.d. RCW 19.255.010 — Personal information—Notice of security breaches. Retrieved November 20, 2025 from https://app.leg.wa.gov/RCW/default.aspx?cite=19.255.010
[13] U.S. Department of Health & Human Services. n.d. Breach Notification Rule – HIPAA for professionals. Retrieved November 20, 2025 from https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html
[14] GDPR-Info. n.d. Article 34 – Communication of a personal data breach to the data subject. Retrieved November 20, 2025 from https://gdpr-info.eu/art-34-gdpr
[15] GDPR-Info. n.d. Article 33 – Notification of a personal data breach to the supervisory authority. Retrieved November 20, 2025 from https://gdpr-info.eu/art-33-gdpr
[16] Washington State Office of the Attorney General. n.d. Washington's data breach notification laws. Retrieved November 20, 2025 from https://www.atg.wa.gov/washington-s-data-breach-notification-laws
[17] Eisenhower Law. n.d. Washington's New Biometrics Law – One of a Kind in the United States. Retrieved November 20, 2025 from https://eisenhowerlaw.com/washingtons-new-biometrics-law-one-kind-united-states/
[18] Washington State Legislature. n.d. Chapter 19.375.020 RCW – Enrollment, disclosure, and retention of biometric identifiers. Retrieved November 20, 2025 from https://app.leg.wa.gov/RCW/default.aspx?cite=19.375.020
[19] U.S. Code. n.d. 15 U.S.C. § 45 – Unfair methods of competition unlawful. Retrieved November 20, 2025 from https://www.law.cornell.edu/uscode/text/15/45
[20] U.S. Department of Homeland Security. 2025. Collection and Use of Biometrics by U.S. Citizenship and Immigration Services (90 FR 49062). Retrieved November 20, 2025 from https://www.federalregister.gov/documents/2025/11/03/2025-19747/collection-and-use-of-biometrics-by-us-citizenship-and-immigration-services
[21] GDPR-Info. n.d. Article 4 – Definitions. Retrieved November 20, 2025 from https://gdpr-info.eu/art-4-gdpr
[22] GDPR-Info. n.d. *Article 9 – Processing of special categories of personal data.* Retrieved November 20, 2025 from https://gdpr-info.eu/art-9-gdpr
[23] GDPR.eu. n.d. Data Protection Impact Assessment Template. Retrieved November 20, 2025 from https://gdpr.eu/data-protection-impact-assessment-template